

Assignment 1 (week 1)

Cybersecurity

Assignment 1

ABSTRACT

This document explains key concepts and terms of Cyber Security in simple language with examples. It covers various security threats, attacks, tools, and practices such as Malware, Phishing, Ransomware, MITM, SQL Injection, Cryptography, MFA, OWASP, and more. The aim is to help learners, students, and professionals understand the basics of cyber threats and the measures to protect data, networks, and systems from cyber-attacks.

Ambikesh Kumar

12 June 12, 2025

Q1. Explain about CIA Triad in Cyber Security with example of each.

CIA Triad in Cyber Security

The **CIA Triad** is one of the most important models in cyber security. It helps to protect sensitive data and information systems from unauthorized access, changes, and attacks. CIA stands for:

1. **Confidentiality**
2. **Integrity**
3. **Availability**

Let's understand each one in detail with examples:

---

1. Confidentiality

Meaning:
Confidentiality means that important and sensitive information is kept secret and is only available to authorized persons. Unauthorized people should not be able to access or see the data.

How to Maintain Confidentiality:

- Using strong passwords
- Data encryption
- Access control (only giving access to trusted users)

Example:
When you use WhatsApp, your chats are protected by end-to-end encryption. This ensures that only you and the person you are chatting with can read the messages — no one else, not even WhatsApp.

---

2. Integrity

Meaning:
Integrity means the data should remain accurate, complete, and unchanged unless done by an authorized person. It ensures that the information is not modified in an unauthorized way.

How to Maintain Integrity:

- Using checksums or hashing techniques
- Digital signatures
- User access control

Example:
If you fill an online form for a government exam, your details (like name, age, marks) must remain correct and should not be changed by any hacker or unauthorized person. Otherwise, your application could get rejected.

---

3. Availability

Meaning:
Availability means that information and resources should always be available when authorized users need them. The system should work properly without unnecessary delays or interruptions.

How to Maintain Availability:

- Regular system maintenance
- Data backups
- Protection from attacks like DDoS (Distributed Denial of Service)

Example:
When you use an ATM to withdraw money, the banking service must be available. If the bank server is down due to some cyber attack or failure, you cannot access your money. This is a failure of availability.

Conclusion:

The **CIA Triad** is the backbone of cyber security. All security policies and technologies are designed by keeping these three principles in mind. If any one of these is broken, it can cause big problems for the system or the user.

Principle	Meaning	Example
Confidentiality	Protecting data from unauthorized access	WhatsApp chats are encrypted
Integrity	Keeping data correct and unchanged	Online exam form data remains unaltered
Availability	Data/service always accessible to users	ATM services should be always working

Q2. Difference between DoS Attack and DDoS Attack.

Difference Between DoS Attack and DDoS Attack

POINT	DOS ATTACK	DDOS ATTACK
FULL FORM	Denial of Service Attack	Distributed Denial of Service Attack
NUMBER OF ATTACKERS	Single computer or internet connection attacks the target.	Multiple computers or devices attack the target system at the same time.
SOURCE	Comes from one machine or one IP address.	Comes from many machines (botnets) from different locations.

SPEED OF ATTACK	Slower compared to DDoS because of a single source.	Very fast and powerful because many systems are used.
DETECTION	Easier to detect and block.	Difficult to detect because traffic comes from many different sources.
COST TO PERFORM	Less expensive as only one machine is needed.	More expensive as many devices are controlled by the attacker.
IMPACT	Causes temporary service disruption.	Can cause large-scale service shutdown and serious damage.

Examples:

1. **DoS Attack Example:**
   A hacker uses their personal computer to flood a website with fake requests to slow it down.
2. **DDoS Attack Example:**
   A hacker controls thousands of infected computers (called a botnet) to flood a website with traffic, making it crash and unavailable to real users.

Conclusion:

- **DoS** is launched from a **single source**.
- **DDoS** comes from **multiple sources** and is much harder to stop.

Q3. What is Ethical Hacking? Explain.

What is Ethical Hacking?

Ethical Hacking means testing a computer system, network, or application to find security weaknesses — but in a legal and safe way.

It is also called **"White Hat Hacking"** because ethical hackers do not harm the system; they help organizations to protect their data from real (malicious) hackers.

Definition:

Ethical Hacking is the process of **legally breaking into computers or networks** to test and improve their security, with the permission of the system owner.

Purpose of Ethical Hacking:

1. To find and fix security holes.
2. To protect data from cyber-attacks.
3. To improve the overall security of a system.
4. To check if unauthorized access is possible.

Who are Ethical Hackers?

- Ethical hackers are also known as **"White Hat Hackers"**.
- They work for companies, governments, and organizations.
- They perform hacking with **proper permission**.

Example:

A bank hires an ethical hacker to test its online banking website. The hacker tries to find any weak points that a criminal hacker might exploit. After finding these points, the bank fixes them to make the website more secure.

Difference Between Ethical Hacker and Malicious Hacker:

ETHICAL HACKER (WHITE HAT)	MALICIOUS HACKER (BLACK HAT)
WORKS WITH PERMISSION	Works without permission
HELPS TO SECURE THE SYSTEM	Tries to steal or damage data
LEGAL	Illegal

Conclusion:

Ethical hacking is a very important method to prevent cyber-attacks. It helps companies and organizations to **stay safe from hackers and protect valuable data**.

Q4. What do you mean by Vulnerability?

What is Vulnerability?

A **vulnerability** is a **weakness or flaw** in a computer system, network, software, or application that can be exploited by attackers (hackers) to gain unauthorized access, damage the system, or steal data.

In simple words, **vulnerability means "a gap or weakness in security"** that can create problems if not fixed.

Examples of Vulnerability:

1. **Weak Password:**
   If you use a simple password like "1234", hackers can easily guess it and break into your account.
2. **Outdated Software:**
   If you do not update your software or apps, hackers can use old flaws (bugs) to attack your system.
3. **Unprotected Wi-Fi:**
   If a Wi-Fi network does not have a strong password, anyone nearby can connect to it and misuse it.

Types of Vulnerabilities:

1. **Hardware Vulnerability** – Weakness in physical devices (e.g., USB ports without security).
2. **Software Vulnerability** – Bugs or errors in applications or operating systems.
3. **Network Vulnerability** – Poorly protected Wi-Fi or unencrypted data transfer.

Conclusion:

Vulnerabilities are dangerous because **hackers can use them to harm a system or steal data**. That's why security updates, strong passwords, and safe practices are important to reduce vulnerabilities.

Q5. What is Penetration Testing?

What is Penetration Testing?

Penetration Testing (also called **Pen Testing**) is a **legal and planned cyber attack** on a computer system, network, or application to find its security weaknesses before real hackers can exploit them.

In simple words, it is like **checking the door and window locks of your house by trying to break in — but legally — to see how strong they are.**

Purpose of Penetration Testing:

1. To identify hidden security weaknesses.
2. To fix vulnerabilities before hackers find them.
3. To improve the security of the system.

Steps of Penetration Testing:

1. **Planning:** Decide what will be tested and get permission.
2. **Scanning:** Gather information about the target system.
3. **Attacking:** Try to break into the system like a real hacker.
4. **Reporting:** Prepare a report of all vulnerabilities found and suggest solutions.

Example:

A company hires a cybersecurity expert to perform penetration testing on its website. The expert tries to hack into the website without causing real damage. If he finds any weakness, he tells the company to fix it before real hackers find it.

Types of Penetration Testing:

1. **Network Penetration Testing** – Tests firewalls, routers, etc.
2. **Web Application Penetration Testing** – Tests websites and apps.
3. **Social Engineering Testing** – Tests if employees can be tricked (e.g., phishing emails).

Conclusion:

Penetration testing is an important part of cyber security that helps organizations stay safe from real cyber-attacks by finding and fixing security gaps in advance.

Q6. Define the following

A) Adware

Adware (Advertising-Supported Software)

Definition:
Adware is a type of software that automatically shows or downloads advertisements on a user's device (computer, smartphone, tablet), usually without the user's permission.

Purpose:
The main purpose of adware is to generate revenue for its creator by displaying ads.

How it works:

- It gets installed along with free software or applications from the internet.
- After installation, it displays pop-up ads, banners, or redirects you to unwanted websites.

Example:
When you download a free game or software from an unofficial site, and suddenly your browser starts showing unexpected ads or new toolbars—that's likely adware.

Harmful or Not?
Some adware is just annoying, but **malicious adware** can also track your browsing behavior and collect personal information without consent.

B) Brute Force Attack

Definition:
A **Brute Force Attack** is a method used by hackers to crack passwords, encryption keys, or login credentials by trying all possible combinations until the correct one is found.

How it works:

- The attacker uses an automated tool or script that keeps guessing passwords (like "1234", "abcd", "password123", etc.) one by one until the right password is discovered.

Example:
If someone is trying to hack into your email by trying every possible password combination until they find the correct one, that is a brute force attack.

Types:

1. **Simple Brute Force:** Trying every possible combination.
2. **Dictionary Attack:** Trying words from a pre-collected list of common passwords.
3. **Credential Stuffing:** Using stolen username-password pairs from previous data breaches.

Protection Measures:
✓ Use strong, long, and complex passwords.
✓ Enable two-factor authentication (2FA).
✓ Use account lockout after repeated failed attempts.

C) Cryptography

Definition:
Cryptography is the process of protecting information by converting it into a secret or unreadable form, so that only authorized people can understand or access it.

Purpose:
To keep data **confidential, secure, and safe** from hackers or unauthorized users.

How it works:

- The original message (called **plaintext**) is changed into an unreadable format (called **ciphertext**) using a mathematical technique and a **key**.
- Only someone with the correct **decryption key** can convert the ciphertext back into readable form.

Example:
When you shop online, your credit card details are encrypted before being sent to the website's server to keep them safe from attackers.

Types of Cryptography:

1. **Symmetric Key Cryptography:**
   Same key used to encrypt and decrypt data.
   Example: AES (Advanced Encryption Standard)
2. **Asymmetric Key Cryptography:**
   Uses a pair of public and private keys.
   Example: RSA algorithm used in secure emails, websites (https://)

D) Cross Site Scripting (XSS)

Definition:
Cross-Site Scripting (XSS) is a type of cyber attack where a hacker injects malicious scripts (usually JavaScript) into trusted websites. When users visit these websites, the malicious script runs in their browser without their knowledge.

Purpose of XSS attack:
✓ Steal sensitive data (like cookies, session tokens, login info)
✓ Redirect users to fake websites
✓ Deface web pages
✓ Perform actions on behalf of the user (like sending messages)

How it works:

- The attacker finds a website that does not properly check or filter user inputs (like search bars, comment boxes).
- They insert a harmful script there.
- When another user opens that webpage, the script automatically runs in their browser.

Example:
On a blog's comment section, a hacker types:

<script>alert('You are hacked!');</script>

If the site does not block this, visitors will see this popup when they view the comment.

Protection Measures:
✓ Validate and sanitize user inputs
✓ Use Content Security Policy (CSP)
✓ Escape special characters in HTML output

E) Hashing

Definition:
Hashing is the process of converting any data (like a password, file, or message) into a fixed-size string of characters, called a **hash value** or **digest**, using a special mathematical function called a **hash function**.

Purpose:
✓ To store data securely (e.g., passwords in databases)
✓ To ensure **data integrity** (to check if data is changed or not)

Important Point:
Hashing is a **one-way process** — you cannot get back the original data from the hash value.

How it works:

- You put any data (like a password or file) into a hash function.
- It produces a unique fixed-length hash.
- Even a small change in the input will create a completely different hash.

Example:
If you type the word “hello” into a hash function (like SHA-256), you will get:
2cf24dba5fb0a30e26e83b2ac5b9e29e1b161e5c1fa7425e73043362938b9824

If you type “Hello” (with capital H), the hash will be completely different.

Uses of Hashing:

✓ Password protection in databases

✓ File integrity checking (e.g., antivirus uses hashes to detect malware)

✓ Blockchain technology

F) Injection Attack

Definition:
An Injection Attack happens when an attacker sends harmful data (called malicious code) into a program (usually through input fields like forms, search bars) to change how the program works or to make it do something bad (like revealing or destroying data).

Purpose:

✓ To steal, modify, or delete data

✓ To gain unauthorized access to systems

✓ To crash or control applications

Common Types:

1. SQL Injection:
   Attacker inserts malicious SQL code into a database query.
   Example: In a login form, the hacker types:
2. ' OR '1'='1

This can trick the database into logging them in without knowing the correct password.

3. Command Injection:
   Hacker inserts commands into a program to execute dangerous system commands.
4. LDAP Injection, XML Injection:
   Similar attacks targeting specific systems like directory services or XML-based services.

Example of SQL Injection:
If a website allows this login input:

Username: admin

Password: ' OR '1'='1

It may log in the attacker without a real password.

Protection Measures:

✓ Always validate and sanitize user inputs

✓ Use prepared statements in databases

✓ Implement strict input controls

G) Keylogger

Definition:
A Keylogger is a type of malicious software (or sometimes a physical device) that records every keystroke a user makes on their keyboard, usually without the user's knowledge.

Purpose:
✓ To steal sensitive information like passwords, credit card numbers, emails, messages, etc.
✓ To spy on the victim's activities.

How it works:

- When the victim types on the keyboard, the keylogger silently records each key pressed.
- The stolen data is then secretly sent to the attacker.

Example:
A user unknowingly downloads a keylogger hidden inside free software. The keylogger records everything the user types, including their bank password, and sends it to the hacker.

Types of Keyloggers:

1. Software Keylogger: Malicious programs installed on a system.
2. Hardware Keylogger: Small physical devices placed between the keyboard and computer.

Protection Measures:
✓ Install reliable antivirus software
✓ Avoid downloading unknown or pirated software
✓ Regularly update the operating system and software
✓ Use virtual keyboards for sensitive information entry

H) Malware

Malware (Malicious Software)

Definition:
Malware is a general term for any **software designed to harm, exploit, or damage computers, networks, or data** without the user's consent.

Purpose:
✓ Steal sensitive data (like passwords, credit card info)
✓ Damage or disable systems
✓ Gain unauthorized access
✓ Spy on users

Types of Malware:

1. **Virus** – Infects and spreads to other files or programs.
2. **Worm** – Spreads automatically across networks.
3. **Trojan Horse** – Pretends to be useful but contains harmful code.
4. **Ransomware** – Locks files and demands money to unlock them.
5. **Spyware** – Secretly collects user data.
6. **Adware** – Shows unwanted ads.

Example:
A fake free game is downloaded, but secretly installs spyware that tracks everything the user does on their device.

Protection Measures:
✓ Use trusted antivirus/anti-malware software
✓ Avoid downloading software from unknown sources
✓ Update software and operating systems regularly
✓ Be careful with email attachments and links

l) Man-in-the-Middle Attack (MITM)

Definition:
A **Man-in-the-Middle (MITM) Attack** happens when an attacker secretly intercepts and possibly alters the communication between two parties (like a user and a website) without their knowledge.

Purpose:
✓ To eavesdrop (listen secretly) on private conversations or data
✓ To steal sensitive information (like passwords, credit card numbers)
✓ To manipulate or modify the information being exchanged

How it works:

- You connect to a public Wi-Fi (like in a coffee shop).
- An attacker on the same network intercepts the data you send (like login details or messages).
- You think you're securely communicating with a website, but the attacker is reading everything.

Example:
You try to log in to your bank's website using free public Wi-Fi. A hacker nearby performs an MITM attack and steals your login credentials by secretly capturing your data traffic.

Types of MITM Attacks:

1. **Wi-Fi Eavesdropping** – Intercepting data on unsecured Wi-Fi networks.
2. **Session Hijacking** – Taking control of a user's active session.
3. **HTTPS Spoofing** – Making a website appear secure when it's not.

Protection Measures:
✓ Use secure, encrypted connections (look for HTTPS)
✓ Avoid using public Wi-Fi for sensitive transactions
✓ Use VPN (Virtual Private Network)
✓ Enable two-factor authentication (2FA)

J) Ransomware

Definition:

Ransomware is a type of malicious software (malware) that locks or encrypts a victim's files or entire computer system and demands money (ransom) to unlock or restore access.

Purpose:
✓ To force victims to pay money (usually in cryptocurrency) to regain access to their data or system.

How it works:

- You download a fake or infected file (like an email attachment).
- The ransomware silently encrypts (locks) your files.
- A ransom message appears asking for payment to unlock the files.

Example:
The WannaCry Ransomware Attack (2017) infected computers worldwide, encrypting files and demanding ransom in Bitcoin.

Ransom Message Example:
"Your files have been encrypted! Pay $500 in Bitcoin within 72 hours to get them back."

Effects of Ransomware:
✓ Loss of access to important files
✓ Financial loss (if ransom is paid)
✓ Data leaks if attackers threaten to publish files

Protection Measures:
✓ Backup important files regularly
✓ Do not open suspicious email attachments or links
✓ Keep antivirus and all software updated
✓ Use strong firewalls and security policies

K) Social Engineering

Definition:
Social Engineering is a type of attack where the attacker tricks or manipulates people into giving away confidential information, such as passwords, bank details, or personal data, instead of directly hacking computers or systems.

Purpose:
✓ To exploit human trust or carelessness to gain unauthorized access to systems or data.

How it works:

- The attacker pretends to be a trusted person (like a bank employee, technical support, or friend).
- They trick the victim into revealing sensitive information, clicking malicious links, or downloading harmful files.

Example:
A hacker calls pretending to be from your bank and asks for your OTP or password, claiming it's for verification purposes. If you tell them, they can steal money from your account.

Common Social Engineering Techniques:

1. **Phishing:** Fake emails or messages that look real.
2. **Vishing:** Voice calls pretending to be trusted sources.
3. **Smishing:** Fake SMS messages.
4. **Pretexting:** Creating a false scenario to get information.

Protection Measures:
✓ Be cautious with unknown calls, emails, and messages.
✓ Never share sensitive data (like OTP, passwords) with anyone.
✓ Verify the identity of the person or company contacting you.

L) Spoofing

Definition:
Spoofing is a cyber attack where the attacker pretends to be a trusted person, device, or organization to deceive the victim into giving sensitive information, downloading malware, or performing unsafe actions.

Purpose:
✓ To trick victims into trusting fake communications or devices
✓ To steal data or gain unauthorized access

How it works:

- The attacker **fakes an identity** to make their messages, websites, emails, or devices look real.
- The victim believes the attacker is genuine and may share passwords, click on fake links, or download harmful files.

Example:
You get an email that **looks like it's from your bank**, but it's actually sent by a hacker. If you click the link in the email, it takes you to a fake website designed to steal your login credentials.

Types of Spoofing:

1. **Email Spoofing:** Fake emails that seem to come from a trusted sender.
2. **IP Spoofing:** Fake IP addresses used to hide the attacker's real identity.
3. **Caller ID Spoofing:** Fake phone numbers that appear to be from known contacts.
4. **Website/URL Spoofing:** Fake websites that look exactly like real ones.

Protection Measures:
✓ Always verify the source of emails, calls, and websites
✓ Check URLs carefully (look for spelling mistakes or strange domains)

✓ Use antivirus and anti-phishing tools
✓ Do not share sensitive information unless you are 100% sure of the sender's identity

M) Spyware

Definition:
Spyware is a type of **malicious software (malware)** that secretly installs itself on your device to monitor your activities and collect personal information without your knowledge.

Purpose:
✓ To **steal sensitive data** like usernames, passwords, credit card numbers
✓ To **track user behavior** (websites visited, keystrokes, etc.)
✓ To send this information to attackers or advertisers

How it works:

- Spyware silently runs in the background of your computer or phone.
- It records what you do — like the sites you visit, your typed messages, or even screenshots.
- The stolen data is then sent to the attacker or used for targeted ads.

Example:
A free software or app you download secretly includes spyware. While you use your device, it collects your browsing history and sends it to advertisers or hackers.

Types of Spyware:

1. **Keyloggers:** Record keystrokes.
2. **Trojans:** Disguised as useful software but secretly spy on the user.
3. **Adware with spying features:** Displays ads while also collecting data.

Effects of Spyware:
✓ Slows down the device
✓ Steals sensitive information
✓ Causes unwanted ads or redirects

Protection Measures:
✓ Use reliable antivirus and anti-spyware software
✓ Avoid downloading unknown or suspicious apps
✓ Keep your software and OS updated
✓ Be cautious with email attachments and pop-ups

N) SQL Injection

Definition:
SQL Injection is a type of **injection attack** where an attacker inserts or "injects" malicious SQL (Structured Query Language) code into a website's database query, tricking the system into performing unauthorized actions like revealing, modifying, or deleting data.

Purpose:
✓ To **steal sensitive information** (like usernames, passwords)
✓ To **bypass login pages**
✓ To **delete or change database content**

How it works:

- The attacker finds an input field on a website (like a login form, search box) that does not properly check the user input.
- They enter malicious SQL code instead of normal data.
- The database runs the harmful command.

Example:
On a login page, an attacker enters this instead of a password:

' OR '1'='1

This tricks the database into thinking the password is correct, allowing the attacker to log in without knowing the real password.

Effects of SQL Injection:
✓ Unauthorized access to sensitive data
✓ Corruption or deletion of database content
✓ Possible total control over the server

Protection Measures:
✓ **Validate and sanitize** all user inputs
✓ Use **Prepared Statements (Parameterized Queries)**
✓ Set **proper database permissions** (least privilege)
✓ Use **Web Application Firewalls (WAFs)**

O) Trojan Horse

Definition:
A **Trojan Horse** (or simply **Trojan**) is a type of **malware** that **pretends to be a useful or harmless program** but actually contains harmful code that can damage your system, steal data, or create a backdoor for hackers.

Purpose:
✓ To trick the user into installing malware
✓ To secretly steal information
✓ To allow attackers to control the infected device remotely

How it works:

- You download and run a file thinking it is a game, software, or document.
- In the background, the Trojan installs malware that can steal data, spy on you, or give hackers access to your system.

Example:
You receive an email with an attachment named “Free Game.exe.”

If you open it, the Trojan gets installed and may:
✓ Steal your passwords
✓ Install spyware or ransomware
✓ Allow a hacker to control your computer remotely

Effects of a Trojan:
✓ Data theft
✓ System damage
✓ Unauthorized access
✓ Network attacks

Protection Measures:
✓ Never download files from untrusted sources
✓ Use updated antivirus software
✓ Be cautious with email attachments and links
✓ Regularly update your operating system and applications

P) Virtual Private Network (VPN)

Definition:
A **Virtual Private Network (VPN)** is a secure service that creates an **encrypted connection (or tunnel)** between your device (computer, phone) and the internet. It hides your real IP address and protects your online activities from being tracked or hacked.

Purpose:
✓ To **protect privacy and personal data** on the internet
✓ To **hide your real location and identity**
✓ To **safely use public Wi-Fi networks**
✓ To **access blocked or restricted websites**

How it works:

- When you connect to a VPN, your internet data is **encrypted**.
- The data travels through a secure server operated by the VPN service.
- Websites see the VPN server's IP address, **not your real one**.

Example:
If you use free public Wi-Fi at a coffee shop without a VPN, hackers may intercept your data (like passwords).
If you use a VPN, your data is encrypted, and hackers cannot read or steal it.

Benefits of VPN:
✓ Protects against hackers on public networks
✓ Keeps browsing history private from ISPs (Internet Service Providers)
✓ Bypasses geo-blocked content (like accessing Netflix US from India)

Protection Measures:
✓ Use a **trusted and secure VPN service**
✓ Don't use free VPNs without checking for security risks
✓ Ensure VPN connection is active before accessing sensitive sites

Q) Zero Day Vulnerability

Definition:
A **Zero-Day Vulnerability** is a **security flaw or weakness** in software or hardware that is **unknown to the software maker or security team**. Because no fix (patch) exists yet, hackers can exploit this vulnerability to launch attacks.

Why it's called "Zero-Day"?:
Because the developer has **"zero days"** to fix the problem — they just discovered it, and attackers may have already started using it.

Purpose of Attackers:
✓ To secretly access systems
✓ To steal sensitive data
✓ To install malware or control devices

Example:
A hacker finds an unknown weakness in a popular browser. Before the browser company knows about it and fixes it, the hacker uses the flaw to install spyware on users' computers.

Risks of Zero-Day Vulnerabilities:
✓ No defense is available (since the issue is unknown)
✓ Can cause serious data breaches or system compromise
✓ High risk for organizations, governments, and users

Protection Measures:
✓ Keep software and operating systems **regularly updated**
✓ Use strong **antivirus and intrusion detection systems**
✓ Stay informed via security updates from trusted sources
✓ Apply security patches as soon as they are released

R) Data Filtration

Definition:
Data Filtration refers to the process of filtering, selecting, or blocking data that passes through a network or system, based on certain rules or criteria. It is used to prevent unauthorized, harmful, or unwanted data from entering or leaving a system.

Purpose:
✓ To protect systems from malicious data or harmful content
✓ To allow only safe, required, and approved data to pass through
✓ To enhance privacy and security of the network

How it works:

- Filters are set up in devices like firewalls, proxies, or routers.
- These filters check data packets, emails, or web traffic.
- Suspicious or unauthorized data is blocked, while safe data is allowed.

Example:
✓ A company firewall blocks all email attachments with ".exe" files to prevent potential

malware from entering the network.
✓ A web filter prevents employees from accessing social media websites during work hours.

Types of Data Filtration:

1. Email Filtering: Blocks spam or phishing emails.
2. Web Filtering: Restricts access to certain websites.
3. Packet Filtering: Controls network traffic based on IP address, port, or protocol.

Protection Measures:
✓ Use firewalls with proper filtration rules
✓ Keep filters and rules updated regularly
✓ Combine filtration with antivirus and intrusion detection systems for better protection

S) Air Gapping

Definition:
Air Gapping is a security measure where a computer or network is physically isolated from any other computers or networks, especially the internet. This means there is no wired or wireless connection to the outside world, making it extremely difficult for hackers to remotely access the system.

Purpose:
✓ To protect highly sensitive data or critical systems from cyberattacks
✓ To prevent malware, ransomware, or remote hacking attempts

How it works:

- The computer or system remains completely disconnected from public or private networks.
- Data transfer (if needed) is done manually using USB drives, CDs, or other removable media.

Example:
✓ Military computers handling top-secret data are usually air-gapped.
✓ Nuclear power plant control systems are air-gapped to prevent remote sabotage.

Benefits of Air Gapping:
✓ Extremely secure against remote attacks
✓ Protects critical infrastructure like power grids, banks, or defense systems

Limitations:
✓ Manual data transfer increases the risk of insider threats (like plugging in infected USB drives)
✓ Less convenient and harder to maintain or update software

Protection Measures:
✓ Strict control over physical access to the air-gapped system
✓ Scan all removable media for malware before use
✓ Monitor for insider activity

T) Red Team / Blue Team

1) Red Team

Definition:
A **Red Team** is a group of security experts that **simulate real cyber-attacks** on an organization's system to find vulnerabilities before actual attackers do.

Purpose:
✓ To act like real hackers (attackers)
✓ To discover and exploit weaknesses in security systems
✓ To test how well the organization can detect and respond to attacks

Example:
A Red Team may try to break into a company's internal network by sending phishing emails or exploiting software bugs — just like real attackers would.

---

2) Blue Team

Definition:
A **Blue Team** is a group of defenders responsible for **protecting the organization's systems and data** from cyber-attacks. Their job is to detect, respond, and block attacks — including those launched by the Red Team during tests.

Purpose:
✓ To monitor systems for signs of attack
✓ To block and mitigate threats
✓ To strengthen the organization's defenses after learning from attacks

Example:
When the Red Team simulates an attack, the Blue Team uses **firewalls, antivirus, intrusion detection systems (IDS)**, and other tools to stop them and prevent damage.

Red Team vs. Blue Team Summary:

RED TEAM	BLUE TEAM
ACTS LIKE ATTACKERS	Acts like **defenders**
FINDS WEAKNESSES	Protects systems
TESTS SECURITY BY HACKING	Detects & responds to threats
OFFENSIVE SECURITY	Defensive Security

Why is this useful?
✓ This practice helps organizations **improve their security** by knowing both the attackers' tricks and the defenders' capabilities.

U) Cyber Hygiene

Definition:
Cyber Hygiene refers to the **good habits and practices** that individuals and organizations should follow regularly to keep their computers, devices, and online accounts **safe, secure, and protected from cyber threats**.

Purpose:
✓ To prevent cyber-attacks, malware infections, and data breaches
✓ To maintain overall digital safety and system health

How it works:
Like daily personal hygiene (brushing teeth, washing hands), cyber hygiene includes **routine checks and actions** to reduce the risk of cyber threats.

Examples of Cyber Hygiene Practices:

1. **Using strong, unique passwords** for every account
2. **Enabling two-factor authentication (2FA)**
3. **Regularly updating software and antivirus programs**
4. **Avoiding suspicious emails, links, and websites**
5. **Backing up important data regularly**
6. **Using secure Wi-Fi and VPNs**
7. **Limiting the use of public or shared computers for sensitive tasks**

Benefits of Cyber Hygiene:
✓ Protects personal and organizational data
✓ Reduces chances of malware or ransomware attacks
✓ Ensures smooth and secure operation of systems

V) Advanced AES (Advanced Encryption Standard)

Definition:
AES is a widely used **encryption algorithm** that helps protect sensitive data by converting it into an unreadable form called ciphertext. Only someone with the **correct secret key** can decrypt (unlock) this data and read the original message.

Purpose:
✓ To ensure **data confidentiality**
✓ To protect data during storage or transmission (such as over the internet)
✓ To make sure only authorized users can access the original information

How it works:

- AES uses **symmetric encryption**, meaning the **same secret key** is used for both encryption and decryption.

- It processes data in **blocks of 128 bits** and can use **key sizes of 128, 192, or 256 bits** — larger keys provide stronger security.

Example:
When you send a message through a secure app like WhatsApp, AES may be used to encrypt the message so that only the receiver (with the correct key) can read it.

Key Features of AES:
✓ **Fast and efficient** — used in hardware and software
✓ **Highly secure** — trusted by governments, banks, and industries worldwide
✓ **Standardized** — adopted by the U.S. government to protect classified data

Uses of AES:
✓ Secure messaging apps (like WhatsApp, Signal)
✓ Disk encryption (BitLocker, FileVault)
✓ VPN connections
✓ HTTPS websites for secure communication

Protection Measures:
✓ Keep your **encryption keys secure**
✓ Use longer AES keys (like **256-bit**) for highly sensitive data
✓ Combine AES with other security measures (like two-factor authentication)

Q7. Write all of the types of hackers and mention what they do ?

🔍 **Types of Hackers and What They Do**

---

1. White Hat Hackers (Ethical Hackers)

✓ **Work legally** to protect systems.
✓ Find and fix security weaknesses.
✓ Help organizations to improve cybersecurity.
✓ Examples: Cybersecurity professionals, Penetration testers.

---

2. Black Hat Hackers (Malicious Hackers)

✓ **Hack illegally** for personal gain, money, or harm.
✓ Steal data, spread malware, or damage systems.
✓ Examples: Cybercriminals, Identity thieves.

---

3. Grey Hat Hackers

✓ Work in the **middle ground** — sometimes ethical, sometimes not.
✓ May break into systems **without permission** but not for harm; often to point out flaws.
✓ Sometimes inform the company but may demand payment.

---

4. Red Hat Hackers

✓ **Fight against Black Hat hackers** using aggressive methods.
✓ Attack and destroy the systems of malicious hackers to stop them.
✓ Known as **"vigilante hackers."**

---

5. Blue Hat Hackers

✓ **Test software and systems** for bugs and vulnerabilities before official release.
✓ Sometimes hired by companies like Microsoft for software testing.
✓ Also refers to beginners who hack for revenge but lack deep skills.

---

6. Green Hat Hackers

✓ **Beginner hackers (Newbies or "Noobs")** who are eager to learn.
✓ Actively explore and study hacking techniques.
✓ Not yet skilled but passionate about hacking.

---

7. Script Kiddies

✓ **Amateur hackers** who use existing hacking tools or scripts created by others.
✓ Usually hack for fun or attention, not skill.
✓ Can accidentally cause harm without understanding the impact.

---

8. Hacktivists

✓ Hack for a **political, social, or religious cause**.
✓ Their motive is to spread messages, disrupt services, or protest.
✓ Example: Anonymous group hacking government websites.

---

9. State-Sponsored Hackers

✓ Hired by **government agencies** to perform cyber espionage, steal data, or attack other nations' infrastructure.
✓ Work in the interest of national security or warfare.

---

10. Whistleblower Hackers

✓ Hackers who leak sensitive information from inside an organization to expose corruption, unethical practices, or secrets.
✓ Example: Edward Snowden.

🔐 **Summary Table:**

Hacker Type	What They Do
White Hat	Ethical hacking to protect systems
Black Hat	Illegal hacking for personal or financial gain
Grey Hat	Mixed intentions, may help but without permission
Red Hat	Fights and attacks Black Hat hackers
Blue Hat	Tests systems before release or for revenge
Green Hat	Beginner hackers learning the craft
Script Kiddies	Use others' tools without real knowledge
Hacktivists	Hack for political or social causes
State-Sponsored	Government-backed hackers for espionage
Whistleblowers	Leak secret data to expose wrongdoing

Q8. Write the types of testing and describe them ?

🔍 **Types of Testing in Cyber Security**

---

1. Vulnerability Assessment (VA)

✓ Scans systems or networks to **identify known vulnerabilities**.
✓ Checks for missing patches, weak passwords, misconfigurations.
✓ **Does not exploit the vulnerability**, only reports it.

Example:
Using tools like **Nessus** or **OpenVAS** to detect unpatched software.

---

2. Penetration Testing (Pen Testing)

✓ **Simulates a real attack** on a system to find weaknesses.
✓ Tries to **exploit vulnerabilities** to see how far an attacker can go.
✓ Helps organizations fix security holes before real hackers find them.

Types of Pen Testing:

- **Black Box Testing:** Tester knows nothing about the system.
- **White Box Testing:** Tester has full knowledge (like code, network details).
- **Grey Box Testing:** Tester has partial knowledge.

---

3. Security Auditing

✓ **Manual or automated inspection** of code, policies, and processes.
✓ Checks if the organization is following security standards and regulations (like ISO, PCI-DSS).

Example:
Reviewing a company's password policy or checking software code for flaws.

---

4. Risk Assessment

✓ Identifies **potential risks and threats** to the system or data.
✓ Evaluates the **impact and likelihood** of these risks.
✓ Helps in deciding **which security measures to prioritize**.

Example:
Checking if sensitive customer data is at risk of theft and what harm it could cause.

---

5. Security Scanning

✓ Automated tools scan for **security weaknesses**.
✓ Scans can be at the **network level or application level**.
✓ Less deep than penetration testing but quick and regular.

Example:
Running a vulnerability scanner on a company’s website to detect open ports or outdated software.

---

6. Ethical Hacking

✓ Performed by **Certified Ethical Hackers (CEH)**.
✓ **Legally breaks into systems** to find and fix security flaws.
✓ Similar to penetration testing but broader in scope.

---

7. Posture Assessment

✓ Combines **Risk Assessment, Security Scanning, Ethical Hacking, and Security Auditing**.
✓ Gives a **complete picture of an organization's security health**.

---

8. Red Team Testing

✓ Red Team acts like **real attackers** to test the defense system's detection and response ability.
✓ Tests how well the security team (Blue Team) can react to attacks.

---

9. Blue Team Testing

✓ Blue Team works to **detect, block, and respond** to attacks (including those by Red Team).
✓ Focuses on improving **monitoring, alerting, and incident response**.

Summary Table:

Testing Type	Purpose
Vulnerability Assessment	Find known security flaws without exploiting them
Penetration Testing	Exploit vulnerabilities to assess security strength
Security Auditing	Check for compliance with security policies
Risk Assessment	Identify and evaluate possible risks
Security Scanning	Automated scan to detect weaknesses
Ethical Hacking	Legally hack systems to improve security
Posture Assessment	Complete security health check
Red Team Testing	Simulate real attacker behavior
Blue Team Testing	Defend and respond to attacks

Q9. What is a virtual machine ?

Virtual Machine (VM)

Definition:
A **Virtual Machine (VM)** is a **software-based computer** that behaves like a real, physical computer. It allows you to run an **operating system (OS)** and applications **inside another computer (the host)** as if it were a separate machine.

✓ One physical computer (host) can run **multiple virtual machines** at the same time.
✓ Each VM is **isolated** from the others — problems or viruses in one VM **do not affect the host or other VMs**.

How does a VM work?

A **hypervisor (virtual machine manager)** creates and runs VMs.
✓ Examples of hypervisors: **VMware, VirtualBox, Hyper-V.**
✓ You can install **different OS** (Windows, Linux, macOS) on a VM, even if the host OS is different.

Example:

✓ You have a **Windows laptop**, but you run **Linux inside a VM** to safely test Linux software.

Uses of Virtual Machines in Cyber Security:

1. ✓ **Testing malware** in a safe environment
2. ✓ Running risky or unknown programs without harming the main system
3. ✓ Learning and practicing hacking or ethical hacking
4. ✓ Creating **secure, isolated environments** for development or research

---

Benefits of Virtual Machines:

✓ **Safe testing ground** for security tools
✓ **Cost-effective** — no need for multiple physical machines
✓ Easy to **reset or delete** if things go wrong

Limitations:

❌ VMs can be **slower than physical machines**
❌ They need **enough memory and CPU power** from the host machine

---

Q10. Write the types of web ? And describe them with example?

🌐 **Types of Web**

---

1. Surface Web (Visible Web)

✓ This is the **part of the internet accessible to everyone** using standard web browsers like Chrome, Firefox, etc.
✓ It includes all the websites that are **indexed by search engines** like Google, Bing, Yahoo.

Examples:
✓ Google.com
✓ Wikipedia.org
✓ Facebook.com
✓ YouTube.com

Key Points:
✓ **Easily accessible**
✓ No special software or permission required
✓ Around **4% of the total web**

---

2. Deep Web

✓ The Deep Web contains content that is **not indexed by search engines** and **cannot be accessed directly** via normal search.
✓ Requires **passwords, login credentials, or private access**.

Examples:

✓ Online banking portals

✓ Private email inboxes (like Gmail, Yahoo Mail)

✓ University library databases

✓ Corporate internal networks

Key Points:

✓ **Legal and safe** part of the web

✓ Estimated to be **90% of the entire web**

✓ Used for privacy, secure communication, and private data storage

---

3. Dark Web

✓ The Dark Web is a **hidden part of the Deep Web**, purposely kept **anonymous and untraceable**.

✓ Special software like **Tor Browser** is required to access it.

✓ Often associated with **illegal activities**, but also used for privacy and freedom of speech in restricted countries.

Examples:

✓ Dark web marketplaces (like Silk Road – now shut down)

✓ Anonymous forums

✓ Onion websites (.onion domain)

Key Points:

✓ Not accessible via normal browsers

✓ Used for **illegal and legal purposes**

✓ Requires **special tools** like Tor, I2P

Summary Table:

Web Type	Description	Examples
Surface Web	Open and searchable via Google, Bing, etc	Google, Facebook, Wikipedia
Deep Web	Hidden from search engines, requires login	Gmail inbox, Bank accounts, Databases
Dark Web	Anonymous, needs special browser (Tor)	.onion sites, Dark Web forums

---

Important Notes:

✓ **Surface Web** = Public and visible to everyone

✓ **Deep Web** = Private but legal (e.g., emails, subscriptions)

✓ **Dark Web** = Hidden + Anonymized (can involve illegal content)

Q11. Define the following

1) Sniffing

Definition:
Sniffing is the process of **capturing and monitoring data packets** flowing through a computer network. It allows attackers (or network administrators) to see information being sent or received over the network.

✓ The captured data may include **passwords, emails, credit card numbers**, or other sensitive information.

Types of Sniffing:

1. **Passive Sniffing:**
   ✓ **Listens silently** to network traffic without altering anything.
   ✓ Works on **hub-based networks** where data is sent to all connected devices.

Example:
Capturing unencrypted login credentials in public Wi-Fi.

---

2. **Active Sniffing:**
   ✓ Actively **sends traffic or manipulates the network** to capture data not meant for the attacker.
   ✓ Used in **switched networks** where direct traffic cannot be seen without interference.

Example:
ARP Spoofing to divert network traffic to the attacker's machine.

Tools Used for Sniffing:

✓ **Wireshark** (for network analysis)
✓ **Tcpdump**
✓ **Cain & Abel** (for password sniffing)

Risks of Sniffing:

❌ Sensitive data theft
❌ Password stealing
❌ Privacy violation

How to Prevent Sniffing:

✓ Use **encrypted connections (HTTPS, SSL/TLS)**
✓ Employ **VPNs (Virtual Private Networks)**
✓ Secure your Wi-Fi with **strong passwords and WPA3 encryption**

Here is a simple and clear explanation of **OWASP (Open Web Application Security Project)** in Cyber Security:

---

2) OWASP (Open Web Application Security Project)

Definition:
OWASP is a **non-profit organization** that works to improve the **security of software and web applications**.
It provides **free resources, tools, and guidelines** to help developers, testers, and organizations build secure software.

Purpose of OWASP:

✓ To **educate developers** and security professionals on secure coding practices.
✓ To **identify and list the most critical security risks** in web applications.
✓ To provide **solutions and best practices** to prevent these risks.

Famous OWASP Resources:

1. **OWASP Top 10:**
   ✓ A list of the **10 most common and dangerous web application vulnerabilities**.
   ✓ Examples from the list:

- **SQL Injection**
- **Cross-Site Scripting (XSS)**
- **Broken Authentication**
- **Security Misconfiguration**

2. **OWASP ZAP (Zed Attack Proxy):**
   ✓ A free tool to **find security issues in web applications**.

Why OWASP is Important?

✓ Helps developers **avoid security mistakes** while coding.
✓ Used by organizations worldwide to **create secure applications**.
✓ Makes the web safer for **users and companies**.

Example Use:

✓ A company checks its new website using **OWASP Top 10 guidelines** to ensure there are no major vulnerabilities before launching.

3) NAC (Network Access Control)

Definition:
Network Access Control (NAC) is a **security solution** that controls **which devices or users are allowed to connect** to a private network.
It ensures that only **trusted and secure devices** can access the network resources.

Purpose of NAC:

✓ To **protect the network** from unauthorized devices or infected systems.
✓ To **check the security level** (like antivirus status, OS updates) of each device before allowing it to connect.
✓ To prevent **malware or hacking attempts** by blocking risky devices.

How NAC Works:

1. When a device tries to join the network (Wi-Fi or LAN), NAC:
   ✓ **Identifies the device and user**
   ✓ **Checks device compliance** (Is antivirus installed? Is the OS updated?)
   ✓ Decides to either **allow, deny, or restrict access** based on security policies.

Example:

✓ In an office, if an employee's laptop **doesn't have the latest antivirus updates**, NAC will **block or limit its access** to protect the network.

Benefits of NAC:

✓ Stops **unauthorized devices** from accessing the network
✓ Ensures **only secure devices** are allowed in
✓ Reduces the risk of **malware spreading** inside the network

---

Examples of NAC Solutions:

✓ Cisco Identity Services Engine (ISE)
✓ Aruba ClearPass

4) MFA (Multi-Factor Authentication)

Definition:
Multi-Factor Authentication (MFA) is a **security method** that requires users to provide **two or more different types of proof (factors)** to verify their identity before they can access an account or system.

Purpose of MFA:

✓ To add an **extra layer of security** beyond just a username and password.
✓ Helps prevent unauthorized access even if **passwords are stolen**.

Types of Authentication Factors:

1. **Something You Know:**
   ✓ Password, PIN, or answer to a security question.
2. **Something You Have:**
   ✓ Smartphone, OTP (One-Time Password), Smart Card, Security Token.
3. **Something You Are:**
   ✓ Fingerprint, Face ID, Retina Scan (Biometrics).

Example:

✓ When you log in to Gmail:
1️⃣ Enter password (Something you know)
2️⃣ Enter OTP sent to your phone (Something you have)

✓ Even if someone guesses your password, they **cannot log in without your phone**.

Benefits of MFA:

✓ **Greatly improves security**
✓ **Protects against password theft**
✓ **Reduces the chance of hacking, phishing, or unauthorized access**

Common MFA Tools:

✓ Google Authenticator
✓ Microsoft Authenticator
✓ Authy

5) Digital Certificate

Definition:
A **Digital Certificate** is an **electronic document** used to prove the **ownership of a public key**. It helps verify the **identity of a website, person, or organization** to ensure secure communication over the internet.

Purpose of Digital Certificate:

✓ To establish **trust between users and websites**.
✓ To make sure you are connecting to the **real, genuine website**, not a fake one.
✓ Used in **SSL/TLS** to create a **secure connection (HTTPS)**.

What does a Digital Certificate contain?

✓ **Owner's public key**
✓ **Owner's name / domain name**
✓ **Certificate Authority (CA) details** (who issued the certificate)
✓ **Validity period**
✓ **Digital signature of the CA**

Example:

✓ When you visit a secure website like **https://www.amazon.com**, the browser checks Amazon's **digital certificate** to ensure the site is genuine and encrypted.
✓ You can see the **padlock symbol** 🔒 in the browser address bar because the site has a valid digital certificate.

Issued By:

✓ **Certificate Authorities (CAs)** such as:

- **DigiCert**
- **Let's Encrypt**
- **GoDaddy**

Benefits of Digital Certificate:

✓ Ensures **data encryption** between server and client
✓ Confirms the **identity** of websites or services
✓ Protects against **phishing and man-in-the-middle attacks**

6) Big Data Security

Definition:
Big Data Security refers to the **measures, tools, and practices** used to **protect large volumes of data (Big Data)** from unauthorized access, theft, alteration, or destruction.

✓ Big Data includes **huge amounts of structured, semi-structured, and unstructured data**, such as customer records, social media content, videos, logs, etc.

Why is Big Data Security Important?

✓ Big data contains **sensitive and valuable information** (like financial records, personal data, business secrets).

✓ If not secured, this data can be **targeted by cybercriminals** leading to data breaches, identity theft, and financial losses.

Challenges in Big Data Security:

1. **Volume:**
   ✓ Huge amounts of data are difficult to secure.
2. **Variety:**
   ✓ Different data formats (text, images, videos) need different security measures.
3. **Velocity:**
   ✓ Big data is generated at high speed (real-time data), making quick security checks harder.
4. **Veracity:**
   ✓ Ensuring the accuracy and trustworthiness of big data is challenging.

Key Components of Big Data Security:

✓ **Data Encryption:**
Protect data during storage and transfer.

✓ **Access Control:**
Allow only **authorized users** to view or modify data.

✓ **Data Masking:**
Hiding sensitive data to protect privacy.

✓ **Monitoring & Auditing:**
Track data access and changes to detect suspicious activities.

✓ **Compliance:**
Follow regulations like **GDPR, HIPAA, PCI-DSS** to protect personal and financial data.

Example:

✓ An e-commerce company stores customer purchase data.
✓ Big Data Security ensures that this data is **encrypted and accessible only to authorized employees**, preventing hackers from stealing it.

Benefits of Big Data Security:

✓ **Protects sensitive data** from breaches.
✓ Ensures **customer trust**.
✓ Helps in **regulatory compliance**.

Here is a simple and clear explanation of **Cyber Espionage** in Cyber Security:

---

7) Cyber Espionage

Definition:
Cyber Espionage is the **unauthorized and secret use of computer networks** to access confidential or sensitive information, typically for **political, military, or economic gain**.

✓ It is like **spying in the digital world**, where attackers steal important data from governments, companies, or individuals.

Purpose of Cyber Espionage:

✓ To gather **secret information** such as:

- Military plans
- Government strategies
- Business trade secrets
- Research & technology data

✓ Used by **nations, state-sponsored hackers, or cybercriminal groups** to gain an advantage over others.

How Cyber Espionage is Done:

✓ **Phishing emails** to steal login credentials
✓ **Malware or spyware** installed on target computers
✓ **Network intrusions** to access protected servers
✓ **Exploiting software vulnerabilities**

Example:

✓ A hacker group sends fake emails to employees of a defense organization.
✓ Once an employee clicks the link, spyware is installed, and the group secretly gathers military secrets.

Risks of Cyber Espionage:

❌ National security threats
❌ Loss of company intellectual property (like designs, patents)
❌ Huge financial losses
❌ Damage to reputation

Prevention of Cyber Espionage:

✓ Use **strong firewalls and intrusion detection systems**
✓ Regularly update and patch software

✓ Train employees on **phishing awareness**
✓ Encrypt sensitive data